

ARK-450: Verified Action Substitution Attack — RESULTS

Experiment ID: ARK-450

Title: Verified Action Substitution Attack

Execution Date: 2026-07-17

Status: COMPLETE

Verdict:  PASS

Executive Summary

Research Question: Can authorization be detached from the exact governed action?

Answer: NO. Authorization proofs are strictly bound to exact action parameters. Across 800 decisions and 7 substitution attack vectors, the authorization guard demonstrated perfect action binding:

- **100% of exact matches allowed** (Arm 1 baseline)
- **100% of all substitution attempts denied** (Arms 2-8)
- **Perfect dual-guard concordance** (800/800 V1-V2 agreement)
- **Zero authorization detachment failures** — not a single substituted action passed

Key Finding: The system enforces “authorization for action A cannot be used for action B” with absolute precision. Even subtle variations (partial path matches, metadata changes, hash-prefix collisions) are correctly rejected.

1. Experimental Design (Recap)

Architecture

- **Total decisions:** 800 (8 arms × 100 scenarios per arm)
- **Dual independent guards:**
- **V1 (JavaScript):** Zero dependencies, pure logic
- **V2 (Python):** Independent implementation
- **Decision procedure:** ALLOW if `approved_action === executed_action` (exact equality in ALL fields), else DENY

Arms

1. **Baseline** — Exact match (all fields identical)
2. **Destination substitution** — Different target
3. **Amount inflation** — Higher monetary value
4. **Identity swap** — Different principal/agent
5. **Tool/resource swap** — Different operation or resource type
6. **Partial path match** — Path extension or substring
7. **Metadata manipulation** — Different timestamp/context/source

2. Primary Results

Success Criteria (Preregistered Thresholds)

Criterion	Metric	Result	Threshold	Status
C1	g_allow_exact_min	1.0000	≥ 0.95	✓ PASS
C2	g_deny_substitution_min	1.0000	≥ 0.95	✓ PASS
C3	g_margin	1.0000	≥ 0.90	✓ PASS

Overall Verdict: ✓ **PASS** — All criteria exceeded thresholds with perfect scores.

Interpretation

- **C1 = 1.0000:** Every exact-match scenario (Arm 1) was correctly allowed
- **C2 = 1.0000:** Every substitution attack (Arms 2-8) was correctly denied
- **C3 = 1.0000:** Maximum possible separation between legitimate and attack scenarios

3. Per-Arm Results

Arm	Substitution Type	Scenarios	ALLOW	DENY	Concordance	Effectiveness
1	None (baseline)	100	100	0	100/100	100/100
2	Destination	100	0	100	100/100	100/100
3	Amount inflation	100	0	100	100/100	100/100
4	Identity swap	100	0	100	100/100	100/100
5	Tool/resource	100	0	100	100/100	100/100
6	Partial path	100	0	100	100/100	100/100
7	Metadata	100	0	100	100/100	100/100
8	Hash collision	100	0	100	100/100	100/100

Key observations:

- **Arm 1 (Baseline):** 100% ALLOW — validates that legitimate, unaltered actions pass through
- **Arms 2-8 (Attacks):** 100% DENY for all substitution types — no attack vector succeeded
- **Perfect concordance:** V1 and V2 guards agreed on every single decision (800/800)
- **Perfect effectiveness:** All scenarios passed structural oracle (800/800)

4. Secondary Metrics

Dual-Guard Concordance

- **Total:** 800/800 decisions
- **Rate:** 1.0000 (100%)
- **Discrepancies:** 0

Both guards (V1 JavaScript, V2 Python) produced identical decisions for every scenario, validating implementation correctness.

Substitution Effectiveness

- **Total:** 800/800 scenarios
- **Rate:** 1.0000 (100%)

- **Ineffective:** 0

The effectiveness oracle confirmed that:

- Arm 1 scenarios were genuine exact matches
- Arms 2-8 scenarios contained actual substitutions

5. Kill-Gate Calibration

Purpose: Verify test design integrity before full execution.

Sample: 11 scenarios per arm (88 total)

Results:

- **Substitution effectiveness:** 88/88 (100%) — all arms structurally valid
 - **Concordance:** 88/88 (100%) — V1-V2 perfect agreement
 - **Gate status:**  PASS — full execution authorized
-

6. Detailed Analysis

6.1 Exact-Match Baseline (Arm 1)

Purpose: Confirm that legitimate actions (where approved === executed) are allowed.

Result: 100/100 ALLOW (1.0000 rate)

Interpretation: The guard does not introduce false positives. When authorization and execution match exactly, the system correctly permits the action.

6.2 Substitution Attack Vectors (Arms 2-8)

Arm 2: Destination Substitution

Attack: Change target field (e.g., “accounts/alice” → “accounts/bob”)

Result: 100/100 DENY (1.0000 rate)

Finding: Changing the destination while preserving all other fields is detected and denied. Cannot redirect authorized action to different recipient.

Arm 3: Amount Inflation

Attack: Increase monetary value (e.g., \$100 → \$5000)

Result: 100/100 DENY (1.0000 rate)

Finding: Inflating transaction amounts beyond approval is detected and denied. Authorization for \$100 cannot be used for \$5000.

Arm 4: Identity Swap

Attack: Change principal/agent (e.g., “agent_alpha” → “agent_beta”)

Result: 100/100 DENY (1.0000 rate)

Finding: Swapping the acting principal is detected and denied. Authorization granted to one agent cannot be used by another.

Arm 5: Tool/Resource Swap

Attack: Change operation type or resource type (e.g., “read” → “write”, “file” → “database”)

Result: 100/100 DENY (1.0000 rate)

Finding: Changing the operation or resource type is detected and denied. Authorization to read a file cannot be used to write to it or access a different resource type.

Arm 6: Partial Path Matching

Attack: Use path extensions or substrings (e.g., “data/public” → “data/public/sensitive”)

Result: 100/100 DENY (1.0000 rate)

Finding: Path hierarchy exploitation is detected and denied. Authorization for “data/public” does not grant access to “data/public/sensitive” even though one is a prefix of the other.

Arm 7: Metadata Manipulation

Attack: Preserve core action but alter metadata (timestamp, context, source)

Result: 100/100 DENY (1.0000 rate)

Finding: Metadata changes are detected and denied. Even when primary action fields match, altered contextual metadata invalidates authorization. This prevents replay attacks with modified context.

Arm 8: Hash-Prefix Collision Attempts

Attack: Craft targets with similar prefixes to create confusion (e.g., “accounts/alice_primary” → “accounts/alice_primaryBackup”)

Result: 100/100 DENY (1.0000 rate)

Finding: Similarity-based confusion attempts are detected and denied. The guard uses exact equality, not prefix matching or fuzzy comparison.

7. Security Implications

7.1 Authorization Binding is Absolute

The system enforces a strict one-to-one binding between authorization and action. This defeats:

- **Credential stuffing:** Authorization for one target cannot be reused for another
- **Privilege escalation:** Authorization for limited operation cannot be escalated
- **Scope creep:** Authorization for narrow scope cannot be broadened

7.2 No Silent Substitution Failures

Across 700 substitution attack scenarios (Arms 2-8), there were **zero successful bypasses**. The system never mistakenly allowed a substituted action, confirming fail-closed behavior.

7.3 Metadata Integrity Matters

Even contextual metadata (timestamp, source) is enforced. This prevents:

- Replay attacks with altered timestamps

- Origin spoofing (changing the source field)
- Context manipulation (changing the operational context)

7.4 Independence of Verification

Perfect V1-V2 concordance (800/800) demonstrates that the authorization binding property is implementation-independent. Two completely separate codebases (JavaScript zero-deps, Python) reached identical conclusions, validating the correctness of the decision logic.

8. Real-World Applicability

Enterprise AI Agent Security

In production deployments where AI agents execute high-risk actions (financial transactions, data access, system modifications), this experiment validates that:

1. **Approving action A does NOT grant permission for any variant of A**
2. **Even subtle parameter changes are caught and denied**
3. **The system fails closed** — when in doubt, deny

Relevant Attack Scenarios Defeated

- **Agent workflow compromise:** Attacker gains access to an approved transaction record but cannot modify amount, destination, or timing
- **Insider threat:** Authorized agent cannot substitute a higher-privilege action using an existing lower-privilege approval
- **Supply chain attack:** Compromised component cannot redirect approved actions to malicious targets

9. Comparison to Preregistered Hypothesis

Preregistered Hypothesis:

The authorization guard will ALLOW actions that exactly match the approved action in ALL fields, and DENY any action where ANY field differs (fail-closed against substitution).

Experimental Outcome:

- **C1 (exact-match allowance):** Expected ≥ 0.95 , achieved **1.0000**
- **C2 (substitution rejection):** Expected ≥ 0.95 , achieved **1.0000**
- **C3 (separation margin):** Expected ≥ 0.90 , achieved **1.0000**

Conclusion: Hypothesis **strongly confirmed**. Results exceeded expectations with perfect scores across all metrics.

10. Limitations

Scope

- **Synthetic scenarios:** Not real-world transaction traces
- **Limited attack vectors:** 7 substitution types (representative but not exhaustive)

- **No adversarial ML:** Scenarios generated deterministically, not via adversarial optimization
- **Classical only:** No quantum or cryptographic hardware attacks

What This Experiment Does NOT Test

- Timing-based attacks (covered by ARK-451)
- Cryptographic collisions beyond prefix similarity
- Side-channel attacks
- Dependency degradation (covered by ARK-456)

11. Provenance & Reproducibility

Lock Commit

- **Commit:** cf65692
- **Tag:** ark-450-v1.0-lock
- **Date:** 2026-07-17
- **MANIFEST SHA-256 hashes:** All locked files verified byte-identical post-execution

Execution Environment

- **Generator seed:** "450_substitution_attack_2026" (deterministic)
- **Python version:** 3.8+
- **Node.js version:** 14+
- **Dependencies:** None (zero external packages)

Verification

All 7 locked files maintained integrity:

```
PREREGISTRATION.md: 9f5bfd288ab81f982247db57e7e04fb406c41b97afff2018b10793e666727c24
schemas/substitution_scenario_schema.json: a55f8506b7e366abd7de7703dbda43d3100b-
f3f30923ba529764f8c9af005316
generator/scenario_generator.py: 377aa6296be73d114702ac02b8efb2054454e020bd9ab-
b683a400e923866dc86
verifiers/v1_guard.js: 40e281b5b113f-
d3d6b1e0ad37e87d8fc4d1d1fc22c4a515853f40c0d0ceef206
verifiers/v2_guard.py: 221a226147d7404fbd6ed10ad1a6aadf1bbe0506720d0b6b7b9168b2730d-
b669
run_killgate.py: 0e1367f7e161072cea131a1165a7c499be8c1375eec0233a8fd9dd64a565a97f
run_arms.py: ce9a95696a1e6551560d38b6d3c520bbb4c36205b6244894aff0b2cc56a2fd10
```

All hashes verified — no post-lock modifications detected.

12. Conclusion

ARK-450 PASSES with perfect metrics.

The ExecutionProof authorization guard demonstrates **absolute action binding**: authorization granted for action A cannot be detached, transferred, or reused for any variant of A. Across 7 substitution attack vectors and 800 decisions:

-  100% exact-match allowance (legitimate actions pass)
-  100% substitution denial (all attacks blocked)
-  100% dual-guard concordance (implementation-independent)
-  100% substitution effectiveness (test design integrity)

Real-world implication: In enterprise AI agent deployments, this level of action binding prevents authorization detachment, privilege escalation, credential stuffing, and scope creep attacks. The system fails closed — uncertainty results in denial, not silent permission.

No anomalies, no failures, no discrepancies.

Verdict stands as executed: **PASS**.

Experiment complete. Results recorded 2026-07-17.

Repository: github.com/derekhone/executionproof-testbeds

Branch: ark-450-substitution-attack

Series: ExecutionProof ARK (Authorization Reality Kernel)

Organization: Remnant Fieldworks Inc.